

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control	Category	Justification
☒	☐	Least Privilege. Administrative. Access is limited by role		
☐	☒	Disaster recovery plans. Admin. No formal recovery plan		
☒	☐	Password policies. Admin. Password rules enforced through system settings		
☒	☐	Separation of duties. Admin. Financial and IT responsibilities are divided to prevent misuse.		
☒	☐	Firewall. Technical. A network firewall is active to block unauthorized external access		
☐	☒	Intrusion detection system (IDS). Technical. No IDS currently implemented		
☒	☐	Backups. Tech. Regular data backups performed weekly and stored securely offsite.		
☒	☐	Antivirus software. Tech. Antivirus installed on all company devices		
☒	☐	Manual monitoring, maintenance, and intervention for legacy systems. Tech. Older systems require manual oversight; IT staff perform regular checks		
☒	☐	Encryption. Tech. Sensitive customer and payment data encrypted		

in transit and at rest.

- | | | |
|-------------------------------------|-------------------------------------|---|
| ☐ | ☒ | Password management system. Tech, Passwords managed individually |
| ☒ | ☐ | Locks (offices, storefront, warehouse). Physical. Offices storefront and warehouses secured with locks and access control. |
| ☒ | ☐ | Closed-circuit television (CCTV) surveillance. Phys. Cameras installed in storefront and warehouse areas for monitoring and deterrence. |
| ☒ | ☐ | Fire detection/prevention (fire alarm, sprinkler system, etc.). Phys. Functioning smoke detectors and fire suppression systems installed. |

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice	Justification
☒	☐	Only authorized users have access to customers’ credit card information. Botium Toys uses a third-party payment processor	
☒	☐	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment. Encryption used for cardholder data.	
☒	☐	Implement data encryption procedures to better secure credit card transaction touchpoints and data. Payment data is encrypted via HTTPS/TLS during online checkout.	

- | | |
|-------------------------------------|--|
| ☒ | ☐ Adopt secure password management policies. Password complexity and periodic updates are enforced for administrative accounts. |
|-------------------------------------|--|

General Data Protection Regulation (GDPR)

Yes	No	Best practice	Justification
☒	☐	E.U. customers' data is kept private/secured. Customer data is encrypted and access is limited by role;	
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach. IT department has established a breach-notification plan.	
☒	☐	Ensure data is properly classified and inventoried. Data categories are defined in internal systems, though documentation could be improved.	
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data. Basic privacy policies exist, but they are not fully aligned with GDPR standards.	

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice	Justification
☒	☐	User access policies are established. Access control policies are in place; least-privilege principle applied.	
☒	☐	Sensitive data (PII/SPII) is confidential/private. Sensitive data is encrypted and restricted to authorized users.	
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated. Regular backups and validation checks maintain data integrity.	
☒	☐	Data is available to individuals authorized to access it. Systems ensure availability through secure authentication and backup	

recovery processes.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture

Summary

Botium Toys has implemented strong administrative, technical, and physical controls, including least privilege, password policies, firewalls, antivirus software, encryption, and physical locks securing offices, storefronts, and warehouses. The company also maintains CCTV surveillance and functioning fire-detection systems. Compliance practices show progress toward PCI DSS, GDPR, and SOC frameworks through encryption, access controls, and privacy safeguards. However, Botium Toys lacks a formal disaster-recovery plan, intrusion-detection system, centralized password-management tool, and consistent data-backup procedures. Addressing these gaps will strengthen resilience, compliance, and overall security posture across administrative, technical, and physical domains. .

.